RAPPORT D'INCIDENT DE SÉCURITÉ

Compromission d'un compte inutilisé — exercice simulé

Élément	Détail
Auteure	Mariam Balde
Date de rédaction	29 octobre 2026
Référence	INC-2026-001 (exercice)
Type d'incident	Accès non autorisé : compromission d'un compte par devinette du mot de passe
Gravité	Élevée
Statut	Clos
Méthode	Cycle de gestion des incidents NIST SP 800-61
Note	Scénario simulé à partir de l'analyse du journal connexions.log. Adresses IP fictives (RFC 5737).

1. Résumé

Le 28 octobre 2026, un attaquant depuis l'adresse externe 198.51.100.7 a deviné le mot de passe du compte test, inutilisé depuis un an, après deux tentatives échouées. Il a créé un compte supplémentaire (support2) pour conserver un accès. L'incident a été détecté par l'analyse des journaux, escaladé au responsable, puis confiné en 10 minutes. Les deux comptes ont été neutralisés et des mesures de prévention sont proposées.

2. Chronologie

Heure	Événement
10:30:00	Échec de connexion sur le compte test depuis 198.51.100.7
10:30:05	Deuxième échec de connexion, même compte, même IP
10:31:00	Connexion réussie sur le compte test : début de la compromission
10:45	Détection lors de l'analyse du journal de connexions (échecs suivis d'un succès)
10:50	Vérification : l'attaquant est toujours connecté et tente d'accéder aux dossiers partagés. Escalade au responsable
10:55	Confinement : compte test désactivé, IP 198.51.100.7 bloquée sur le pare-feu
11:30	Découverte d'un compte créé par l'attaquant (support2) : désactivé
12:00	Vérifications terminées, compte test supprimé, incident clos

3. Détection et analyse

Extrait du journal :

```
2026-10-28 10:30:00 FAILED user=test ip=198.51.100.7
2026-10-28 10:30:05 FAILED user=test ip=198.51.100.7
2026-10-28 10:31:00 SUCCESS user=test ip=198.51.100.7
```

- **Indicateur clé :** des échecs suivis d'une connexion réussie, depuis une adresse externe, sur un compte que personne n'utilise.
- **Indicateur de compromission (IoC) :** adresse IP 198.51.100.7 ; compte support2 créé sans autorisation.
- **Action :** collecte des faits (session active, actions de l'attaquant) avant toute modification, puis escalade au responsable.

4. Confinement

- Désactivation du compte test, sans suppression, pour conserver les preuves.
- Blocage de l'adresse IP 198.51.100.7 sur le pare-feu.
- Changement des mots de passe des comptes potentiellement concernés.

5. Éradication et récupération

- Recherche de mécanismes de persistance : comptes créés, fichiers, programmes, tâches planifiées.
- Désactivation du compte support2 créé par l'attaquant.
- Suppression du compte test, devenu inutile, une fois les preuves collectées.
- Surveillance renforcée des connexions dans les jours suivants.

6. Cause racine

Un compte de projet inutilisé depuis un an est resté actif, avec un mot de passe faible et sans protection contre les tentatives répétées ni double authentification.

7. Retour d'expérience et actions

Action	Priorité	Objectif
Inventaire mensuel des comptes et désactivation des comptes inutilisés	Élevée	Supprimer les portes d'entrée oubliées
Blocage automatique après plusieurs échecs de connexion	Élevée	Empêcher la devinette des mots de passe
Double authentification (MFA) sur tous les comptes	Élevée	Rendre un mot de passe volé inutilisable
Alerte automatique sur « échecs puis succès » depuis une IP externe	Moyenne	Détecter plus tôt

Le retour d'expérience est mené sans recherche de coupable : l'objectif est de corriger le processus, pas de sanctionner une personne.

8. Ce que j'ai appris

- **Observer → Prévenir → Agir :** comprendre et escalader avant de modifier quoi que ce soit.
- **Désactiver plutôt que supprimer** pendant l'incident, pour conserver les preuves.
- **Chercher la persistance :** un attaquant laisse souvent un moyen de revenir.
- **Traiter la cause racine,** pas seulement les symptômes.